CINECONNECT

Audit remediation and deployment record

14 October 2026 - Release 2026.10.14-audit2

cine.nalexustechnologies.com

36 original findings	920 Flutter tests	391 backend tests
10 additional findings	Analysis clean	85.75% coverage / 85% target

Deployed with documented capability limits

The production app persists booking drafts, agreed terms, KYC and payout details, travel preferences and runtime configuration. This release also preserves encrypted addresses, equipment serials, billing/contact details, insurance licence numbers and check-in coordinates. Owner forms reload saved values.

File processing uses real ClamAV scans and storage integrity checks. Public media is served only for clean, ready records. Push uses real browser subscriptions, a queued sender and signed display receipts instead of simulated delivery.

Revoked sessions now lose access immediately. Private discovery profiles and public-buyer category bypasses are blocked. Role permission saves and CinePlanner input validation are corrected. Payment mode remains manual bank transfer; existing production records and settings are preserved.

237 real stored files passed scanning. Another 239 historical demo file records have no source bytes and are now marked missing. One simulated historical push-delivery record was relabelled unverified.

SMS and SMTP email are not configured. Native push and several explicitly unsupported capabilities remain unavailable. Browser visual verification and a real browser notification display test could not be completed because the browser connection was unavailable. Full details follow.

The original audit PDF is preserved. This report records the implemented remedies, retained design decisions, evidence and unresolved capability limits; it does not certify that every possible application path is defect-free.

Original findings F01-F06

F01 | High | Signup phone OTP is a local length check

CAPABILITY LIMITED

Removed the fake OTP and resend steps. Signup saves the phone number without claiming ownership verification. SMS OTP remains unavailable because no SMS provider is configured.

Evidence: auth_screens.dart; api/auth.py; registration regression

F02 | High | File worker declares files clean without scanning

FIXED

Installed ClamAV on loopback. Workers verify stored length and SHA-256, scan real bytes, quarantine infections and retry scanner failures. Public media now passes the API scan gate. Rescanned all existing records.

Evidence: services/file_processing.py; api/verification.py; live clean/EICAR checks

F03 | High | Test payout accounts are accepted as verified in production mode

FIXED

Production rejects sandbox payout accounts. Removed test-account creation buttons and replaced them with real account management. Submitted bank accounts remain pending manual verification.

Evidence: api/payments.py; lo09/me10 screens; production payout regression

F04 | High | Reachable legacy dashboard displays fixed talent business data

FIXED

The legacy dashboard route now opens the API-backed marketplace. Removed the fixed talent fixture catalogue from the reachable dashboard path.

Evidence: core_routes.dart; dashboard_screen.dart; models/talent.dart

F05 | High | Booking review terms are omitted from submitted API data

FIXED

Booking requests persist deliverables, usage rights, conditions, category fields and payment percentages. Accepted terms appear in contract snapshots and clauses; agreed percentages generate payment milestones.

Evidence: booking_terms.py; bookings.py; contracts.py; counter/contract regression

F06 | High | KYC identity and bank inputs are not submitted

FIXED

KYC submits encrypted identity numbers, expiry dates and real owned file IDs. Bank name, receiving name, account identifier and ownership confirmation are stored in payout accounts. Submission requires clean required documents.

Evidence: verification_screens.dart; verification.py; payments.py; KYC regression

Original findings F07-F12

F07 | High | Push delivery is recorded as delivered without provider delivery

FIXED

Replaced simulated push delivery with encrypted Web Push subscriptions and a queued sender. Provider acceptance is recorded as sent; delivered requires a signed browser display receipt. Relabelled one historical simulated delivery as unverified.

Evidence: web_push.py; notifications.py; push receipt regression; live metadata repair

F08 | High | Live public payment configuration still reports sandbox

FIXED

The live API now runs with APP_ENV=production and manual_bank_transfer payment mode. Public origins use the actual HTTPS domain. Production guards reject sandbox financial inputs.

Evidence: private production configuration; live public-config and health checks

F09 | Medium | Booking Save draft shows success without saving

FIXED

Save draft creates or updates a server booking. Reopening a listing restores its draft and selected project, dates and terms. Failed sends retain the saved draft ID for retry.

Evidence: bookings_controller.dart; dp_booking_request_form_screen.dart; draft regression

F10 | Medium | Negotiation counter amount starts at fixed PKR 275,000

FIXED

Counter-offer amount initializes from the current server offer instead of PKR 275,000.

Evidence: dp_negotiation_thread_screen.dart; Flutter suite

F11 | Medium | Editable negotiation payment schedule is never sent

FIXED

Counter-offers send their edited payment schedule. The API validates positive portions totalling 100 and carries the accepted schedule into contracts and milestones.

Evidence: bookings_repository.dart; booking_terms.py; counter/contract regression

F12 | Medium | Influencer packages prefill fixed commercial prices

FIXED

Removed fixed influencer package prices. New commercial packages start with empty pricing inputs and use submitted backend values.

Evidence: influencer_portal_screen.dart; Flutter suite

Original findings F13-F18

F13 | Medium | Business notifications do not consult stored channel preferences

FIXED

Notification creation and delivery consult stored push preferences and enabled devices. Opt-out prevents queueing and cancels pending sends. In-app booking/security records remain available.

Evidence: services/notifications.py; services/web_push.py; opt-out regression

F14 | Medium | Language selection saves a locale but does not localize the UI

CAPABILITY LIMITED

Removed unsupported language choices from Settings. The shipped interface is explicitly English-only; full Urdu translations have not been implemented. Existing locale metadata is retained for compatibility.

Evidence: settings_account_screen.dart

F15 | Medium | Maintenance and forced-update controls return constants

FIXED

Maintenance and forced-update configuration is stored in the database and administered through authenticated Super Admin endpoints and a Settings panel. Bootstrap reads the persisted values.

Evidence: app_settings.py; api/app.py; runtime_settings_panel.dart; admin regression

F16 | Medium | Maintenance page promises a fixed return time

FIXED

The maintenance screen reads the configured message and optional timezone-qualified return estimate. Removed the fixed return time and version promise.

Evidence: runtime_status_screen.dart; runtime settings validation

F17 | Medium | Signup phone, city and referral inputs are dropped

FIXED

Registration sends and stores phone, active city ID and referral code. Phone remains unverified until a real verification process exists.

Evidence: auth_repository.dart; api/auth.py; registration persistence regression

F18 | Low | Role selection silently falls back to a fixed catalogue

FIXED

Role selection uses the active database catalogue, with loading/error/retry states and no silent mock fallback. Internal roles are excluded from public catalogues.

Evidence: role_selection_screen.dart; api/app.py; catalogue regression

Original findings F19-F24

F19 | Low | Signup city choices come from five hardcoded names

FIXED

Signup city selection loads active city IDs from the API. Removed the five-name fallback. Invalid city IDs fail server validation.

Evidence: auth_screens.dart; api/auth.py; registration regression

F20 | Low | Role-specific KYC document instructions are client constants

FIXED

KYC instructions are loaded from a role requirements API. Super Admin can persist labels and required flags for the four supported document types. Server submission enforces those requirements.

Evidence: api/verification.py; AppSetting; verification_screens.dart

F21 | Medium | PDF and CSV saving is web-only

IMPLEMENTED - DEVICE CHECK PENDING

Native saves use the platform file picker and write actual bytes to the selected destination. PDF/CSV callers await the result. Desktop byte writing and cancellation pass tests; physical Android/iOS save dialogs were not exercised.

Evidence: save_download_stub.dart; csv_download_stub.dart; native_download_test.dart

F22 | Low | Distribution statements have no export action

FIXED

Distribution statements now export authenticated CSV data from owned backend reports. Export supports a project filter and escapes spreadsheet formula prefixes.

Evidence: api/specialist.py; ds04 screen; CSV ownership/formula regression

F23 | Low | Talent travel preferences remain an explicit gap

FIXED

Talent travel willingness, radius and active city IDs have persistent API storage and an editor on the availability page. Talent profile payloads include the preferences.

Evidence: api/marketplace.py; TravelPreferencesPanel; persistence regression

F24 | Low | Several Settings controls are fixed or unavailable

CAPABILITY LIMITED

Settings now reflect real push capability and browser subscription state, provider availability and stored preferences. Unsupported SMS, WhatsApp, watermark, biometric and two-factor controls are disabled with explanations; profile visibility links to role management.

Evidence: settings_account_screen.dart; bootstrap capability flags

Original findings F25-F30

F25 | Low | Contract QR verification is unavailable

FIXED

Participants can obtain a QR code and signed verification URL. Public verification checks the current contract content hash and version, returns minimal status data and rejects tampered links.

Evidence: api/contracts.py; contract_verification.html; QR/tamper regression

F26 | Info | Smart match scores are computed locally over API candidates

RETAINED DESIGN

Smart-match scores remain deterministic client computations over API candidates. They are ranking calculations, not fabricated persisted marketplace records.

Evidence: Original audit classification retained; API candidate source preserved

F27 | Info | Contract wizard clause choices are static but saved through APIs

RETAINED DESIGN

Clause choices remain static UI options whose selections are saved through contract APIs. New agreed booking terms are also copied into server contract clauses.

Evidence: Contract wizard and contract API persistence retained

F28 | Info | Brand demo journey has account-specific hardcoded selectors

FIXED

Removed account-specific demo selectors. The brand project journey uses the authenticated brand account, its real projects and backend counts.

Evidence: brand_project_journey.dart; brand portal screens

F29 | Info | Unused fixture business records and a synthetic upload helper remain

FIXED

Deleted unused shared mock business records and the synthetic demo-upload helper. Real uploads require selected bytes and server completion.

Evidence: shared_mock_data.dart removed; AuthController helper removed

F30 | Info | About release label is a fixed 2026.09 string

FIXED

About reads a compile-time release label supplied during deployment. Bootstrap also reports the configured backend release version.

Evidence: cine_about_button.dart; CINECONNECT_RELEASE; RELEASE_VERSION

Original findings F31-F36

F31 | Info | Device drafts, tours and discovery preferences are intentionally local

RETAINED DESIGN

Tours, device draft conveniences and discovery preferences remain local by design. Business booking drafts are now saved to the server separately.

Evidence: Local preference scope retained; F09 supplies server booking drafts

F32 | Info | Selfie capture does not establish automated liveness verification

CAPABILITY LIMITED

Selfie capture is described as manual identity review. The app no longer claims that a camera capture establishes automated liveness.

Evidence: verification_screens.dart; bootstrap liveness=manual_review

F33 | Info | Influencer social metrics are user-entered profile data

CAPABILITY LIMITED

Influencer social handles, reach and metrics are labelled self-reported profile data. No external social-account verification or metric synchronisation is claimed.

Evidence: influencer_portal_screen.dart; bootstrap social_metrics=self_reported

F34 | Low | Push-device registration API has no runtime caller

FIXED

Settings registers and disables actual browser subscriptions through /push-devices. Logout unsubscribes the browser; reusing a subscription for another account disables the prior account device. Native push is unavailable without a provider.

Evidence: browser_push*.dart; cineconnect_push*.js; shared-browser regression

F35 | Info | Create-project Team values are descriptive references, not invitations

RETAINED DESIGN

Create-project Team values remain descriptive references. They do not send invitations or grant project membership; actual membership workflows remain separate.

Evidence: Original audit classification retained; no unsolicited invitations

F36 | Low | Public payment notice stays a demo string in other payment modes

FIXED

The payment notice follows runtime mode. Production explains external bank transfers and proof reconciliation; the demo wording is limited to sandbox mode.

Evidence: api/app.py; live public payment configuration

Additional findings

F37 | Critical | Public registration and role-add could grant internal staff roles

FIXED

Blocked self-assignment of super_admin, finance_admin, reviewer and support_agent. Disabled roles cannot be reactivated by their holder. Public catalogues exclude internal roles. Existing 16 staff accounts were preserved; no internal initial-registration events were found.

Evidence: Four-role regression cases; live registration returns 403

F38 | High | Historical demo file records had no stored bytes

DATA GAP FLAGGED

237 real files passed ClamAV. The other 239 records are historical demo references without stored objects; their scan and processing statuses now say missing. Records were preserved. Missing bytes require originals to be uploaded again.

Evidence: Production-copy rehearsal and production rescan; file counts preserved

F39 | High | Revoked sessions and suspended accounts retained access

FIXED

Access requests now check the persisted session and active account status. Logout, remote-session revocation and revoke-others invalidate access immediately; suspended accounts cannot log in or refresh.

Evidence: test_user_settings.py; test_admin_workflows.py; auth.py; security.py

F40 | Medium | Repeated role permission saves failed and new role status was ignored

FIXED

Permission updates preserve existing associations and apply only the difference. New and existing role assignments both validate and honor active/suspended status.

Evidence: test_admin_workflows.py; admin_control.py

Additional findings

F41 | Medium | Invalid CinePlanner edits reached database errors

FIXED

Production updates validate dates, text lengths, currency, JSON settings and numeric bounds before persistence. Invalid fields return controlled 422 responses without changing saved values.

Evidence: test_cineplanner_edits.py; cineplanner.py

F42 | High | Unpublished discovery profiles were accessible

FIXED

Discovery lists and detail lookups require a public, approved marketplace listing. Direct profile IDs cannot bypass visibility and moderation restrictions; private addresses remain absent from discovery.

Evidence: test_director_discovery.py; director.py

F43 | High | Public buyer restrictions could be bypassed using a category alias

FIXED

Discovery rechecks the resolved item category against buyer permissions after resolving its listing ID, preventing an allowed category path from exposing restricted categories.

Evidence: test_director_discovery.py; director.py

F44 | High | Private form values were discarded as encrypted placeholders

FIXED

Nine private-field columns now store authenticated ciphertext with adequate capacity. Addresses, serials, billing/contact details, licence numbers and check-in coordinates persist. Owner forms reload private values; public serializers omit them. Eighteen historical placeholder values require owner re-entry.

Evidence: test_private_workflow_fields.py; private_field_models_test.dart; migration 9f84c2e7a6b1; live aggregate counts

Additional findings

F45 | High | Saving availability categories failed on valid JSON lists

FIXED

Talent availability categories now accept validated JSON lists, deduplicate selections and preserve saved selections on invalid input. Optional number/date parsers return controlled validation errors for malformed JSON objects and arrays.

Evidence: test_profile_publishing_workflows.py; marketplace.py; projects.py; bookings.py

F46 | High | Crew publication checked talent KYC instead of crew KYC

FIXED

Crew listings now require an active crew role and approved crew-service KYC. Talent KYC alone cannot authorize crew publication; verified crew providers can publish and update the same listing.

Evidence: test_profile_publishing_workflows.py; marketplace.py

Remaining capability and data limits

1. SMS and SMTP email are not configured. SMS verification and email recovery delivery remain unavailable.

2. Native push requires a provider. Browser push is implemented and configured, but a real browser permission/subscription/display test is still pending.

3. Physical Android/iOS file-save dialogs have not been exercised.

4. Automated liveness, verified social metrics, Urdu translations, biometrics, two-factor authentication, WhatsApp delivery and portfolio watermarking are not implemented.

5. 239 historical demo file references have no source bytes. Their records are preserved and marked missing.

6. Eighteen historical private-field values were replaced by placeholder text by the former code. Their original contents were never saved and require owner re-entry.

7. Passing automated tests and coverage checks do not establish that every possible application path is defect-free. Browser visual verification remains pending because no browser is connected.

Historical private fields requiring re-entry

Production contains 18 old placeholder values: 4 location addresses, 2 equipment serials, 3 check-in latitudes and 3 longitudes, 1 brand billing value, 1 distributor email and 1 phone number, and 3 insurance licence numbers. The previous code did not store the submitted contents. Their replacement must come from the owners; the new code preserves and encrypts future submissions.

Validation evidence

Check	Result
Flutter full test suite	920 passed
Backend full suite with MySQL 8.4 and Redis	391 passed; no skipped tests
Backend branch/statement coverage	85.75%; repository target 85%
Flutter analyze	No issues found
Ruff lint and formatting / mypy	Passed / 74 backend source files checked
Web release build	Passed; JavaScript renderer deployed
Browser push lifecycle regression	Passed; Flutter cleanup preserves push worker
Migration rehearsal	Fresh MySQL upgraded through new private-field migration
Real ClamAV verification	Clean file accepted; EICAR test detected
Live public checks	HTTPS, redirect, health, role rejection and access guards passed
Visual/browser notification checks	Pending; browser connection unavailable

Workflow coverage

Regression checks cover restricted role registration and addition, inactive-role reactivation, phone/city/referral persistence, runtime settings permissions, production payout restrictions, scanner failure and integrity handling, KYC requirements and encryption, booking drafts and counter-offer terms, contract snapshots and milestone rounding, QR tampering, travel persistence, CSV ownership/formula safety and push preferences/receipts/shared-browser ownership. Added checks cover private-field encryption and owner reloads, revoked-session access, admin role/permission updates, CinePlanner edits and permissions, discovery privacy and category restrictions, weather cache/outages, delivery retries, seed integrity, 105 missing-record route cases, editable profile/credit persistence, category-list validation, crew/equipment publishing and account-recovery privacy.

Provider responses are mocked in push unit tests. Real VAPID keys and a protected key mount are configured on the server. No end-to-end browser subscription or notification display was observed. No live OpenAI or payment-settlement calls were made.

The web build reports existing WebAssembly compatibility warnings in dependencies. The JavaScript release build succeeds; WebAssembly support is outside this release.

Deployment, preservation and rollback

Live release

Release: 2026.10.14-audit2. Web asset revision: 20261014-audit2. API, worker and scheduler image: cineconnect-prod-api:20261014-audit2. Migration head: 9f84c2e7a6b1.

Release directory: /var/www/cineconnect/releases/20261014-audit2. The web and source release links point into this directory. The source manifest records SHA-256 values for 974 packaged files. The candidate image, tested QA source and release package matched all 74 backend Python source files; dependencies use the previously deployed image base.

Production records preserved

240 users, 476 file rows, 42 bookings, 12 contracts and 10 payout accounts. File availability and legacy simulated-delivery statuses were corrected without deleting these records. Existing 16 staff accounts were preserved.

Protected backup and rollback

Account and host: root@srv951538.hstgr.cloud. Backup directory: /var/backups/cineconnect/audit-completion-20261014. It contains database and storage snapshots before the cutover, container configuration, previous release links and release logs. Earlier web/source backups and file-integrity results remain in /var/backups/cineconnect/audit-remediation-20261014.

A root-only rollback.py is stored in that backup directory. It restores the previous audit1 containers and web links while retaining the widened database columns and later records. The previous containers remain stopped under names ending in -rollback-20261014-audit2. Do not restore an old database snapshot over newer production activity without a separate recovery decision.

The first cutover automatically rolled back when Nginx rejected the transferred web directory ownership. The static files were assigned to root to match the release symlink, and the retry passed. The initial pre-migration backup is retained in the sibling audit-completion-20261014-first-attempt directory.

Service checks

Nginx, the CineConnect API/worker/scheduler, ClamAV and definition updates are active. ClamAV listens only on 127.0.0.1:3310. LUMEN, Nexus web/API and Originality Studio remain active. Disposable MySQL/Redis QA containers were removed after retaining their evidence.

Source and evidence

Local branch: fix/audit-connectivity-2026-10-13, based on main commit b66a4deaa6c6664715af97377842d98742650c76. The repository tracker records every finding. Embedded attachments contain the resolution data, tests, analysis/build logs and source manifest. Credentials and private keys are excluded.

The release is deployed on the server. GitHub publishing was not requested for these remediation changes.